

Securing Node.js Web APIs

By Troy Hunt & Simon Bennett

Official Publication Information

- Category: Application Security
- Standard Price: INR 549.00
- Pages in Original Volume: 290
- Primary Language: English
- International Standard Book Number (ISBN): 978-1492043621
- Digital License ID: BV-536563757269

Volume Synopsis

Combat CSRF, XSS, SSRF, prototype pollution, JWT hijacking, and rate abuse with practical security hardening strategies for Express and Node microservices.

CRYPTOGRAPHIC VERIFICATION NOTICE:

This protected document was downloaded following verified payment confirmation. Unauthorized distribution or copying is strictly prohibited.

Chapter 1: Foundational Principles & Mental Models

Software engineering and system architecture are grounded in clear boundaries and repeatable abstractions. In this volume, Troy Hunt & Simon Bennett demonstrates why modern practitioners must prioritize decoupled design, testability, and deterministic failure isolation.

When designing architectures in high-leverage domains, the most costly mistakes are rarely algorithmic; rather, they stem from implicit coupling, tangled dependencies, and premature optimizations that obscure core domain boundaries.

By establishing strict invariants at the architectural boundary, engineering organizations achieve predictability, zero-downtime evolution, and sustainable velocity across quarters. Every component should possess a solitary, well-defined reason to change.

Chapter 2: Production Hardening & Operational Excellence

Moving from prototypes to enterprise production requires defensive engineering across every layer. Whether managing high-throughput connection pooling in PostgreSQL, securing API gateways with cryptographically signed tokens, or implementing zero-trust access controls, reliability must be intentional.

Key Takeaways for Engineering Teams:

1. Validate inputs early at API borders using strongly-typed schemas (e.g. Zod).
2. Protect persistent storage with connection pools, transactions, and idempotent operations.
3. Cryptographically verify payment signatures and webhook integrity on the server before fulfilling digital assets.
4. Enforce strict authorization checks for all asset streaming and file downloads.
5. Monitor latency, error budgets, and structured logs without leaking confidential credentials.

Thank you for choosing this BookVault digital publication. Happy reading and building!